

Secret Sharing App

It's the key management, stupid!

Vorbemerkung

Im Kontext von [SSI](#) wurde *Secret Sharing* auch schon als *Key Sharding* bezeichnet, was im Kontext von DBs jedoch missverstanden werden könnte, siehe z.B. [Shard Keys](#).

Hintergrund

- [How to Share a Secret](#)
- [On-line Secret Sharing](#)
- etc.
- siehe auch <https://vitalik.ca/general/2021/01/11/recovery.html>

Problem

Zwei-Faktor-Authentifizierung ist super – bis man auf die Recovery Codes angewiesen ist.
Password-Managers sind super – bis man das Master-Password verliert.

Festplatten-Verschlüsselung ist super – bis man die Festplatte in einem neuen Rechner entschlüsseln sollte, aber den Recovery-Key nicht mehr findet.

Dank Kryptographie kann man die Sicherheit von riesigen Datenmengen mit einem verhältnismässig kleinen Geheimnis ermöglichen. Aber dieses Geheimnis darf man nicht verlieren oder veröffentlichen, sonst schliesst man sich selbst aus (Availability) oder erteilt Unbefugten Zugriff (Confidentiality).

Lösung

Eine App zerlegt das Geheimnis auf Basis eines Secret-Sharing-Schemes in n Teile so, dass k ($k < n$) Teile das Geheimnis rekonstruieren können, $k-1$ Teile aber keinerlei Aussage über das Geheimnis ermöglichen. Die n Teile werden an n andere Instanzen der App geschickt. Anschliessend vergisst die App das Geheimnis und die n Teile.

Menta, Felix, Mädä, Myke und Paul verwenden die App. Wenn Paul die anderen persönlich trifft, tauschen ihre App-Instanzen kryptographische Schlüssel aus, damit sie sich in Zukunft übers Internet authentifizieren und vertraulich kommunizieren können. Inspiration: Web of Trust von PGP

Paul hat ein neues Geheimnis, das er nicht verlieren, aber auch nicht off-line aufbewahren möchte. Mit seiner App zerlegt er es in 4 Teile (mit $k = 2$) und schickt sie Menta, Felix, Mädä und Myke.

Paul verliert sein Handy. Mit seinem neuen Handy und einer neuen App-Instanz besucht er möglichst bald Menta, Felix, Mädä und Myke und tauscht frische kryptographische Schlüssel aus.

Paul benötigt das (mittlerweile alte) Geheimnis von oben. Mit seiner App bittet er die Apps von Menta, Felix, Mädä und Myke, ihm ihre Teile zu schicken. Menta ist off-line und Myke

hatte sein Handy noch vor Paul verloren. Aber Felix und Mädä (resp. ihre Apps) reagieren prompt, so dass Paul 2 Teile erhält, womit er das Geheimnis rekonstruieren kann.

Geschäftsmodell

Wer Teile entgegennimmt, aber selbst keine Geheimnisse Teilen möchte (oder höchstens x , z.B. $x = 1$), kann die kostenlose Version der App verwenden. Wer Geheimnisse zerlegen möchte (oder zumindest mehr als x), muss die kostenpflichtige Version der App verwenden. Enterprise-Version? Geheimnisse von juristischen Personen?

Quizfrage

Wäre das wirklich ein Geschäft, oder nur ein cooles Studi-Projekt?!

- Studi 1 implementiert in TypeScript ein state-of-the-art Secret-Sharing-Scheme als OSS
- Studi 2 implementiert in TypeScript den Krempel für authentische & vertrauliche Kanäle
- Studi 3 integriert die Bibliotheken von Studi 1 und Studi 2 in eine App wie skizziert